Responsabilidad Civil y Penal en Sistemas Informáticos

Unidad 9 · Derecho Informático y Seguridad Informática

En esta unidad exploramos cómo las **fallas técnicas**, los **incidentes de seguridad** y las **omisiones profesionales** en entornos tecnológicos pueden generar consecuencias jurídicas de primer orden. Aprenderemos a identificar cuándo una actuación —o la ausencia de ella— compromete la responsabilidad civil o penal de quienes diseñan, implementan, mantienen y administran sistemas informáticos.

by OscarLondero

Desarrollador full/Stack UI/UX - abogado - asesor de empresas - docente tecnológico



¿Cómo trabajarás esta unidad?

01

Análisis conceptual

Lecturas guiadas que introducen los fundamentos de la responsabilidad civil y penal aplicada a tecnología. Se parte de los conceptos jurídicos clásicos y se proyectan sobre el entorno digital actual.

02

Estudio aplicado

Ejemplos prácticos y casos reales donde una falla técnica, una configuración defectuosa o una omisión profesional desencadenaron consecuencias jurídicas concretas.

03

Materiales de referencia

Acceso a normativa, jurisprudencia seleccionada y guías de buenas prácticas que contextualizan los contenidos dentro del ordenamiento jurídico vigente.

04

Encuentro sincrónico

Sesión semanal optativa, pero altamente recomendable, para consultas, refuerzo de contenidos y debate de ejemplos. Un espacio para profundizar colectivamente.

El objetivo transversal de la unidad es desarrollar criterio jurídico-técnico: saber leer una situación informática con ojos de abogado y una norma jurídica con sensibilidad tecnológica.

Hoja de Ruta — Unidad 9

Los siguientes bloques temáticos articulan el recorrido completo de la unidad. Cada uno construye sobre el anterior, avanzando desde lo conceptual hacia lo aplicado.

🔹 Responsabilidad en entornos tecnológicos

Aproximación general a la responsabilidad civil y penal aplicada a sistemas informáticos.

🔹 Fallas, incidentes y daños

Identificación de situaciones donde errores o vulnerabilidades producen consecuencias jurídicas.

🔹 Daño y atribución de responsabilidad

Vínculo entre conducta, omisión, resultado dañoso y deber profesional.

🔹 Deber de prevención y diligencia

Estándar de cuidado esperado y obligación de anticipar riesgos previsibles.

🔹 Buenas prácticas y casos aplicados

Documentación, controles, seguridad, respaldo y análisis de incidentes reales.

🔹 Prevención y cultura de cumplimiento

Prudencia, criterio y documentación adecuada como pilares del ejercicio profesional responsable.

Responsabilidad en Entornos Tecnológicos

Aproximación general a la responsabilidad civil y penal aplicada a sistemas informáticos

Responsabilidad Civil

Surge cuando una conducta —activa u omisiva— provoca un daño a terceros y existe obligación de repararlo. En el ámbito tecnológico abarca a desarrolladores, administradores de sistemas, proveedores de servicios en la nube, operadores de plataformas y cualquier profesional cuya actuación o inacción ocasione perjuicios patrimoniales o morales.

El fundamento puede ser **contractual** (incumplimiento de un acuerdo de nivel de servicio, un contrato de desarrollo o mantenimiento) o **extracontractual** (cuando el daño se produce al margen de una relación previa pero por culpa o negligencia demostrable).

Responsabilidad Penal

Entra en juego cuando la conducta tipificada como delito se ejecuta a través de o sobre un sistema informático. Los tipos penales relevantes incluyen el acceso no autorizado a sistemas, el sabotaje informático, la revelación de secretos, el fraude electrónico y la distribución de malware.

A diferencia de la civil, la penal requiere **dolo o imprudencia grave** y lleva aparejadas sanciones de privación de libertad, inhabilitación profesional o multas penales, además de las eventuales responsabilidades civiles derivadas del delito.

Fallas, Incidentes y Daños

No toda falla técnica genera responsabilidad jurídica, pero muchas sí lo hacen. Entender la tipología de los incidentes es el primer paso para identificar cuándo el Derecho puede intervenir.



Errores de desarrollo

Bugs o defectos en el código que producen comportamientos inesperados: pérdida de datos, cálculos erróneos o interrupciones de servicio. Si el error era previsible y no se adoptaron medidas de prueba razonables, puede fundarse responsabilidad por negligencia en el desarrollo.



Configuraciones defectuosas

Bases de datos expuestas a internet sin autenticación, permisos excesivos, puertos abiertos innecesariamente o reglas de firewall mal diseñadas son ejemplos de configuraciones que, al materializarse en un incidente, revelan falta de diligencia técnica.



Vulnerabilidades no parcheadas

Mantener en producción software con vulnerabilidades conocidas y no aplicar los parches disponibles es una omisión profesional relevante. Si un atacante explota esa vulnerabilidad y causa daño, el administrador o responsable del sistema puede responder civilmente.



Incidentes de seguridad

Ransomware, filtraciones de datos personales, ataques de denegación de servicio o accesos no autorizados. Cuando el incidente era evitable con medidas razonables, el responsable del sistema puede enfrentarse a reclamaciones civiles, sanciones administrativas y, en su caso, consecuencias penales.

Daño y Atribución de Responsabilidad

Para que nazca responsabilidad —civil o penal— es preciso que concurran ciertos elementos estructurales. La ausencia de cualquiera de ellos puede romper la cadena de imputación.



El análisis jurídico de un incidente informático siempre transita por estos cuatro eslabones. En primer lugar se examina la **conducta o la omisión** del profesional: ¿qué hizo o dejó de hacer? A continuación se verifica el **nexo causal**: ¿existe una relación directa entre esa conducta y el daño producido? Después se cuantifica y acredita el **resultado dañoso**: pérdidas económicas, daños a la reputación, violación de derechos de terceros. Finalmente se determina la **imputación**: a quién y en qué medida se atribuye la responsabilidad, considerando posibles concurrencias de culpa o causas excluyentes.

El Deber de Prevención

Anticipar riesgos y adoptar medidas razonables es una obligación jurídica, no una simple recomendación ética

El **deber de prevención** impone a quienes gestionan sistemas informáticos la obligación de identificar, evaluar y mitigar los riesgos previsibles antes de que se materialicen. Su incumplimiento —especialmente cuando el daño era anticipable con conocimientos técnicos ordinarios— es argumento central en muchas reclamaciones de responsabilidad civil por negligencia.

Previsibilidad del riesgo

Un riesgo es previsible cuando un profesional competente en ese campo debería haberlo conocido o anticipado. La existencia de avisos públicos de seguridad (CVE), boletines del fabricante o estándares sectoriales refuerza la previsibilidad y, con ella, el deber de actuar.

Razonabilidad de las medidas

No se exige eliminar todo riesgo —eso sería imposible— sino adoptar las medidas que un profesional prudente y bien informado habría implementado en circunstancias similares. Este juicio de razonabilidad pondera el coste de la medida frente a la probabilidad e impacto del daño.

Obligación de actualización continua

El entorno de amenazas evoluciona constantemente. El deber de prevención no se agota con la instalación inicial del sistema: exige monitorización continua, aplicación de parches, revisión periódica de configuraciones y adaptación a nuevas vulnerabilidades conocidas.

Diligencia Profesional

El estándar de cuidado esperado en el desarrollo, mantenimiento, gestión y administración de sistemas informáticos

La **diligencia profesional** es el parámetro con el que los tribunales miden la conducta del técnico o profesional informático. No se compara al sujeto consigo mismo, sino con el comportamiento que habría tenido un profesional competente, debidamente formado y actualizado, en la misma situación.

Componentes de la diligencia exigible

- **Competencia técnica actualizada:** conocimiento de las tecnologías que se emplean y de sus riesgos conocidos.
- **Seguimiento de estándares:** aplicación de normas reconocidas como ISO/IEC 27001, OWASP, NIST o las guías del CCN-CERT.
- **Comunicación clara:** informar al cliente o empleador de los riesgos identificados y de las limitaciones del sistema.
- **Documentación adecuada:** registrar decisiones, configuraciones y cambios relevantes para poder justificar la actuación profesional ante un eventual litigio.
- **Actualización continua:** mantenerse al día sobre vulnerabilidades, parches y cambios normativos relevantes.

Consecuencias de la falta de diligencia

Cuando se acredita que el profesional actuó por debajo del estándar exigible, las consecuencias pueden ser múltiples y acumulables:

- Responsabilidad civil por daños y perjuicios causados al cliente, a usuarios o a terceros.
- Resolución del contrato por incumplimiento e indemnización contractual.
- Sanciones administrativas en sectores regulados (sanidad, banca, infraestructuras críticas).
- Responsabilidad penal si la imprudencia es grave y está tipificada como delito.
- Daño reputacional y pérdida de habilitaciones o certificaciones profesionales.

⚠ La ignorancia de un riesgo conocido y documentado públicamente no exime de responsabilidad: se considera que el profesional debería haberlo sabido.

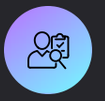
Buenas Prácticas y Prevención

La prevención no es solo una obligación ética: es la mejor defensa jurídica ante un incidente. Un conjunto de medidas técnicas y organizativas bien documentadas puede marcar la diferencia entre responsabilidad y exención.



Documentación

Registrar diseños, decisiones de arquitectura, cambios de configuración y procedimientos operativos. La documentación es prueba de diligencia.



Controles y auditorías

Implementar controles de acceso, revisiones periódicas de seguridad, pruebas de penetración y auditorías de logs para detectar anomalías.



Seguridad activa

Gestión de parches, cifrado de datos en tránsito y reposo, autenticación multifactor y segmentación de redes como medidas mínimas razonables.



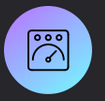
Respaldo y recuperación

Políticas de copia de seguridad periódicas, verificación de su integridad y planes de recuperación ante desastres (DRP/BCP) probados y actualizados.



Actualización continua

Gestión de vulnerabilidades con seguimiento de CVE, ciclos de parcheo definidos y verificación de versiones de dependencias en el software propio.

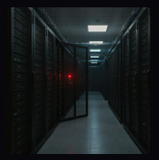


Monitorización

Sistemas de detección de intrusiones (IDS/IPS), alertas en tiempo real, correlación de eventos (SIEM) y revisión periódica de registros de actividad.

Casos Aplicados: De la Falla Técnica al Reclamo Jurídico

El análisis de casos concretos permite comprender cómo los conceptos jurídicos se activan en situaciones reales del entorno profesional tecnológico.



Caso 1: Filtración de datos por base de datos expuesta

Una empresa de comercio electrónico almacena datos de tarjetas de crédito en una base de datos accesible desde internet sin autenticación. Un investigador externo descubre la exposición antes de que lo haga un atacante. La omisión del administrador de sistemas —no configurar correctamente el firewall ni las credenciales— constituye falta de diligencia profesional. Aunque no hubo daño efectivo, el cliente puede reclamar por la **exposición del riesgo** y el regulador puede sancionar por incumplimiento del RGPD.



Caso 2: Fallo de software en sistema crítico

Un proveedor de software hospitalario entrega una actualización sin pruebas suficientes. El bug introduce errores en el cálculo de dosis de medicamentos durante 48 horas. Varios pacientes son afectados. El desarrollador responde civilmente por daños al hospital y a los pacientes. Si la falta de pruebas constituye imprudencia grave en un entorno donde la vida humana está en juego, podría concurrir relevancia penal por imprudencia profesional.

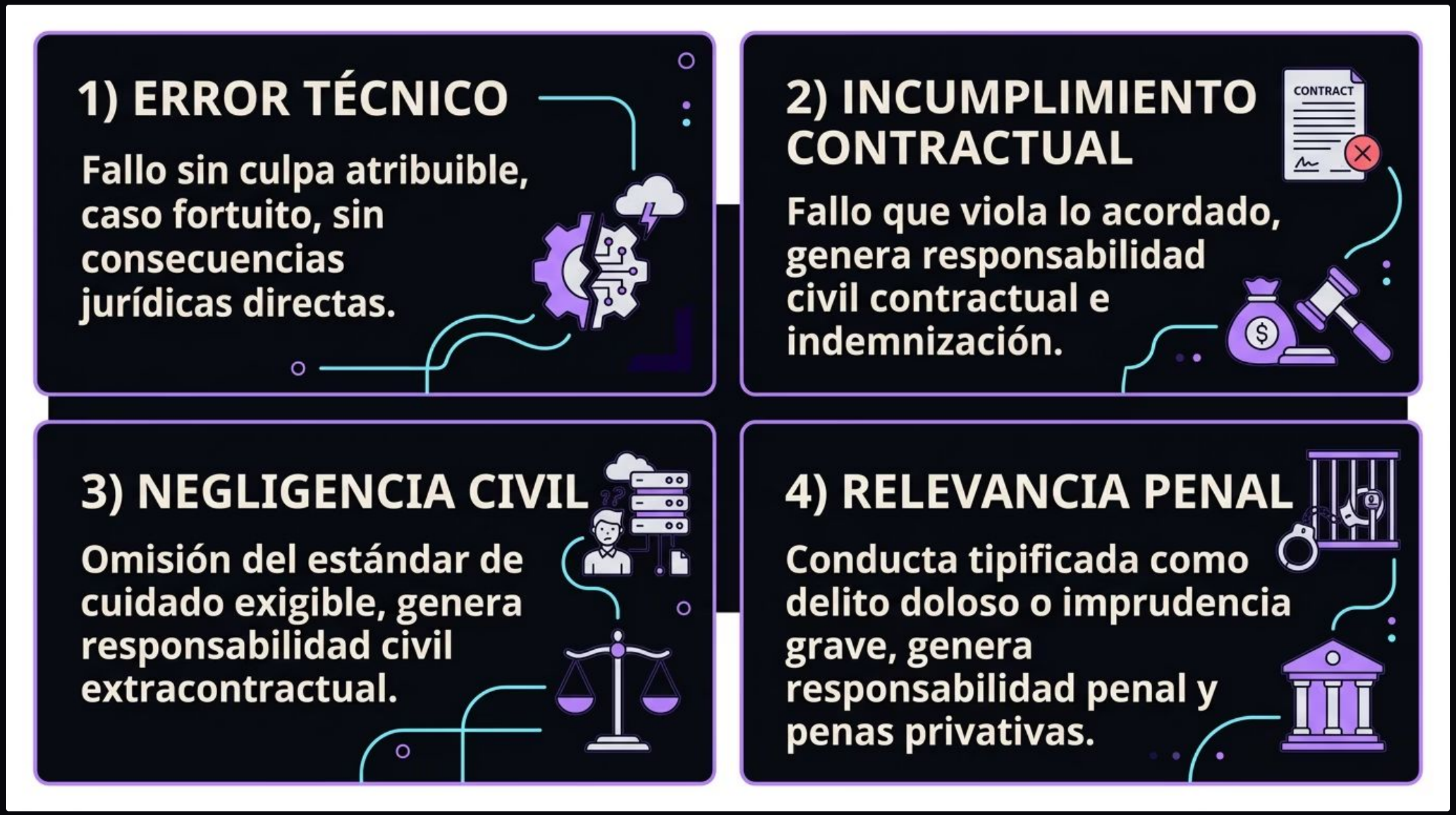


Caso 3: Ransomware por parche no aplicado

Una empresa sufre un ataque de ransomware a través de una vulnerabilidad para la que existía parche disponible desde hacía tres meses. El administrador de sistemas no lo había aplicado por falta de un procedimiento formal de gestión de parches. Los datos cifrados incluyen información de clientes. La empresa responde frente a los clientes; el administrador puede enfrentar responsabilidad interna y el responsable de seguridad (CISO) debe justificar documentalmente por qué se retrasó la actualización.

Lectura Jurídica de Incidentes

Distinguir entre error técnico, incumplimiento contractual, negligencia civil y relevancia penal es una competencia clave para cualquier profesional del sector.



La misma situación fáctica puede ser leída desde estas cuatro perspectivas de forma simultánea o alternativa. Un incidente de seguridad puede al mismo tiempo constituir un incumplimiento del contrato de mantenimiento, una negligencia frente a los usuarios afectados y —si se acredita dolo o imprudencia grave— un ilícito penal. El análisis debe ser siempre contextual: importa el sector, el tipo de datos involucrados, la naturaleza del sistema y las obligaciones específicamente asumidas.

Responsabilidad según el Rol Profesional

La responsabilidad no se distribuye de manera uniforme: el alcance de la obligación de diligencia varía según la posición que cada profesional ocupa en el ciclo de vida del sistema.

1

Desarrollador

Responsable de la calidad, seguridad y corrección del código. Debe seguir prácticas de *secure coding*, realizar pruebas y documentar limitaciones conocidas del software.

2

Administrador de sistemas

Responsable de la configuración, actualización y monitorización del entorno operativo. Su deber incluye la gestión de parches, los controles de acceso y la respuesta ante incidentes.

3

Responsable de seguridad (CISO)

Define la política de seguridad, supervisa su cumplimiento y asegura que los riesgos sean conocidos por la dirección. Responde si omite informar riesgos relevantes o si las políticas son manifiestamente insuficientes.

4

Proveedor de servicios

Sus responsabilidades quedan fijadas en el contrato y en los SLA. La externalización no elimina la responsabilidad del cliente, pero genera una cadena de obligaciones que puede exigirse contractualmente.

Las responsabilidades de cada rol pueden ser **concurrentes**: en un mismo incidente pueden responder el desarrollador, el administrador y el CISO al mismo tiempo, en función de las obligaciones que cada uno tenía y de cómo contribuyeron al daño. La documentación de las funciones y responsabilidades asignadas a cada rol es esencial para delimitar esa imputación.

Prevención y Cultura de Cumplimiento

Actuar con criterio, prudencia y documentación adecuada como pilar del ejercicio profesional en tecnología

¿Qué es la cultura de cumplimiento?

Es el conjunto de valores, procedimientos y hábitos que llevan a los profesionales de una organización a actuar conforme a la legalidad y a los estándares técnicos exigibles, no por temor a sanciones, sino por convicción de que es la manera correcta de operar.

En el ámbito tecnológico, la cultura de cumplimiento implica que cada decisión técnica se toma considerando sus implicaciones jurídicas, éticas y de seguridad, y que queda adecuadamente documentada.

Elementos que la sostienen

- **Políticas claras:** procedimientos escritos para la gestión de incidentes, cambios de configuración y tratamiento de datos.
- **Formación continua:** el equipo debe conocer no solo la técnica sino también el marco normativo aplicable.
- **Registro y trazabilidad:** toda actuación relevante debe dejar huella documental que permita reconstruir qué se hizo, cuándo y por qué.
- **Gestión de riesgos:** identificación periódica de amenazas, evaluación de su probabilidad e impacto y plan de tratamiento documentado.
- **Canal de reporte:** mecanismos para que cualquier miembro del equipo pueda reportar incidentes o riesgos sin temor a represalias.

Marco Normativo de Referencia

La responsabilidad en sistemas informáticos no existe en el vacío: se apoya en un conjunto articulado de normas nacionales, europeas e internacionales que el profesional debe conocer.

Código Penal

Tipifica los delitos informáticos: acceso no autorizado (art. 197 bis), daños informáticos (art. 264), descubrimiento y revelación de secretos, fraude informático y sabotaje. La reforma de 2015 amplió significativamente el catálogo de tipos penales informáticos en España.

RGPD y LOPDGDD

El Reglamento General de Protección de Datos y la Ley Orgánica española complementaria imponen obligaciones técnicas y organizativas cuyo incumplimiento genera responsabilidad administrativa con multas de hasta el 4% del volumen de negocio anual global.

Directiva NIS2

Establece medidas de seguridad obligatorias para entidades esenciales e importantes en la UE, con requisitos de notificación de incidentes en plazos muy estrictos (24h para alerta inicial, 72h para notificación completa) y responsabilidad directa de la alta dirección.

Ley de Servicios Digitales (DSA)

Regula la responsabilidad de plataformas y prestadores de servicios intermediarios en línea. Define obligaciones de diligencia debida y establece un régimen de exención condicionado al cumplimiento de requisitos de moderación y transparencia.

Estándares ISO/IEC 27001

Aunque no son normas jurídicas, la certificación y el cumplimiento de estándares internacionales de seguridad de la información son elementos que los tribunales consideran indicativos de diligencia profesional y pueden servir como defensa ante reclamaciones.

Síntesis y Conclusiones

Lo esencial de la Unidad 9 en una mirada integradora

La tecnología genera responsabilidad jurídica real

Las decisiones técnicas —y las omisiones— tienen consecuencias civiles y penales. El profesional informático no opera en un espacio ajuridico: cada configuración, cada línea de código y cada decisión de seguridad puede ser examinada por un tribunal.

La diligencia es la primera línea de defensa

Actuar conforme al estándar de cuidado exigible —conocer los riesgos, aplicar las medidas razonables, documentar las decisiones— no solo protege a los usuarios sino que protege al propio profesional ante reclamaciones.

Prevenir es más eficaz que reparar

Los costes económicos, reputacionales y humanos de un incidente son siempre superiores a los de las medidas preventivas que lo habrían evitado. La inversión en seguridad es también inversión en reducción de riesgo jurídico.

La cultura de cumplimiento es una ventaja competitiva

Las organizaciones que integran criterios jurídicos y éticos en su práctica tecnológica generan mayor confianza, sufren menos incidentes y se posicionan mejor ante clientes, socios y reguladores en un entorno normativo cada vez más exigente.